

TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

XWorm V7.1 — фишинговая кампания под морскую логистику со спуфом FESCO («Подписанный договор»)

XWorm • RAT • Фишинг • Морская логистика • Извлечение конфига

Параметр	Значение
Дата инцидента	2026-07-06 (перехват); кампания активна 2026-06-18 – 2026-07-06
Дата отчёта	2026-07-06
Классификация	Доставка вредоносного ПО / Commodity RAT
Уровень угрозы	ВЫСОКИЙ
Семейство ВПО	XWorm V7.1
C2	109.248.150[.]234:443
Источник	Noneурот-шлюз входящей почты (агрегированная телеметрия сенсора)

1. Краткое заключение

Управляемый нами honeypot-шлюз входящей почты перехватил фишинговое письмо со спуфом отправителя FESCO (ПАО «Владивостокский морской торговый порт» — российский морской перевозчик), с темой «Подписанный договор». Письмо содержало ZIP-архив, замаскированный под расширением «.r11» — имитирующим том RAR — который на деле включал единственный исполняемый файл Windows, Contract9021_06_07_26.exe, выданный за подписанный договор. Аутентификация отправителя провалена: SPF = Fail, реальный хост отправки — 89.108.121[.]15 (HELO rpnmail.fmf.ru), не связанный с FESCO, при этом адрес envelope-from был подделан на abersenyov@fesco[.]com.

Детонация полезной нагрузки в изолированной песочнице выявила троян удалённого доступа (RAT) XWorm версии 7.1 и позволила извлечь полный рабочий конфиг: адрес управляющего сервера (C2) 109.248.150[.]234 по TCP/443, AES-ключ шифрования трафика и значение mutex. Пивот по извлечённому индикатору C2 в публичных песочницах и репозиториях threat intelligence выявил активную, продолжающуюся кампанию — не менее 33 связанных семплов, использующих ту же инфраструктуру, все объединены темой морской логистики: коносаменты (HBL/MBL), судоводные уведомления грузополучателю («pre-alert») и подписанные договоры, с волнами доставки, наблюдаемыми как минимум с 2026-06-18.

Сочетание реального, проверяемого бренда перевозчика (FESCO), отраслевых приманок и замаскированного расширения архива указывает на целевую кампанию против логистических и морских перевозочных организаций, а не на неизбирательную рассылку. XWorm — широко доступный commodity RAT/стилер, распространяемый через подпольные билдер-наборы; в данной кампании не выявлено уникальных инструментов сверх стандартных возможностей XWorm, однако её устойчивость (многонедельная кампания, выделенный C2, тематическая согласованность) указывает на умеренно ресурсный, финансово или шпионски мотивированный субъект, целящийся в сектор судоходства/фрахтования.

2. Цепочка атаки (Kill Chain)

#	Этап	Описание
1	Подготовка	Подделка личности отправителя под сотрудника FESCO; приманка на тему «подписанного договора», нацеленная на логистических/морских корреспондентов.
2	Доставка	Фишинговое письмо с ZIP-архивом, замаскированным под расширением «.r11», имитирующим том RAR — обход фильтрации по расширению файла.
3	Исполнение	Жертва открывает архив и запускает вложенный исполняемый файл Contract9021_06_07_26.exe, принимая его за документ договора.
4	Распаковка / Инъекция	Полезная нагрузка XWorm (упакована SmartAssembly .NET-packer) распаковывается и внедряется в процесс через SetThreadContext.
5	Обход защиты	Отключение Windows Defender через PowerShell и правку реестра;

		проверка country-code хоста как анти-анализный/geofencing-фильтр.
6	Персистентность	Создание ключа автозапуска в реестре и записи в папке автозагрузки; установка по пути %AppData%\bin.exe.
7	Сбор данных	Сбор данных профилей Outlook, учётных данных почты, данных и cookie браузера.
8	Управление (C2) / Распространение	TLS-связь с 109.248.150[.]234:443; дополнительное распространение через съёмные носители посредством USB.exe.

3. Анализ письма и доставки

3.1. Заголовки письма

Параметр	Значение	Оценка
From	ABersenyov@fesco.com	Спиф
Return-Path / envelope-from	abersenyov@fesco.com	Подделан для совпадения с From
Subject	Подписанный договор	Приманка «договор»
Тело письма (кратко)	«Пожалуйста, ознакомьтесь с приложенным подписанным договором», подпись «Берсенёв Андрей Сергеевич, зам. начальника отдела тепло-водоснабжения ПАО ВМТП, Владивосток»	Правдоподобная легенда «внутреннего сотрудника»

3.2. Аутентификация

Тест	Итог	Детали
SPF	Fail	client-ip = 89.108.121[.]15, HELO = rpnmail.fmf.ru — не авторизован и не связан с fesco.com
DKIM	отсутствует	Валидная подпись отсутствует
DMARC	не выровнен	Домен в заголовке From не согласован с аутентифицированной инфраструктурой отправки

Почтовый шлюз с политикой reject или quarantine по SPF/DKIM/DMARC заблокировал бы или пометил бы это письмо. Наш honeypot-шлюз сохранил его для анализа до применения такой фильтрации.

4. Вредоносное вложение

4.1. Маскировка архива

Атрибут	Значение
---------	----------

Имя файла	Contract9021_06_07_26.r11
Заявленный Content-Type	application/zip
Сигнатура файла (magic)	50 4B 03 04 (PK\x03\x04 — заголовок локального файла ZIP)
Размер	766 309 байт
Оценка	Расширение «.r11» призвано визуально и семантически указывать на сегментированный том RAR, хотя по сигнатуре файл является обычным ZIP. Эта маскировка (MITRE T1036.008) предназначена для обхода фильтров и эвристик аналитиков, ориентированных на исполняемые или распознанные архивные расширения.

4.2. Вложенный исполняемый файл

Атрибут	Значение
Имя файла	Contract9021_06_07_26.exe
Размер	852 992 байта
Формат	PE32 (заголовок MZ), .NET-сборка
Упаковщик	SmartAssembly (обфускатор/упаковщик .NET)
Содержимое архива	Единственный файл — decoy-документ рядом с полезной нагрузкой отсутствует

5. Полезная нагрузка XWorm и извлечённый конфиг

5.1. Рабочий конфиг (по данным детонации)

Поле	Значение
Семейство ВПО	XWorm
Версия билдера	V7.1 (маркер конфига 5.0)
Хост:порт C2	109.248.150[.]234:443
AES-ключ трафика	bK5bLIZIB9durXZWd5PDkvR0hpNHk04+uqD7mNo2KtY=
Mutex	70vLmgcqMEnUJOeL
Путь установки	%AppData%\bin.exe
Модуль USB-распространения	USB.exe

5.2. Наблюдаемое поведение

- Инъекция процесса в незакреплённую (unbacked) память через SetThreadContext.
- Эnumерация/зондирование AMSI перед последующими стадиями исполнения.
- Отключение Windows Defender через команды PowerShell и прямую правку реестра.

- Персистентность через ключ автозапуска в реестре и запись в папке автозагрузки; копирование полезной нагрузки в %AppData%\bin.exe.
- Кража учётных данных и данных, нацеленная на профили Outlook, данные почтового клиента и хранимые браузером данные/cookie.
- Анти-песочничные проверки на основе аппаратных идентификаторов и наличия интерфейса IDE-диска.
- Проверка country-code/локали, согласующаяся с geofencing или валидацией цели.
- Самораспространение на съёмные носители через выделенный компонент USB.exe.

6. Инфраструктура C2

Атрибут	Значение
IP C2	109.248.150[.]234
Порт	443/TCP (TLS)
ASN / Хостинг	AS203557 SIA RixHost / DATA CLUB-NL — латвийский регистратор, присутствие датацентра в Нидерландах (район Zwolle/Lelystad)
ОС хоста	Windows Server 2019
Открытые сервисы	TCP/135 (RPC), TCP/3389 (RDP), TCP/5985 + TCP/47001 (WinRM) — согласуется с вручную администрируемой операторской машиной, а не автоматизированной bulletproof-панелью; порт 443 не виден обычным сканерам и, по всей видимости, обслуживает панель C2 только по требованию
AbuseIPDB	уверенность в злоупотреблении 0/100 (недорепортован)
ThreatFox (abuse.ch)	Отслеживается как C2 ботнета XWorm с 2026-06-18, confidence 75
Вспомогательный стейджер	185.27.134[.]124 — зафиксирована доставка загрузчика на базе .vbs
Ресурсы за Cloudflare	104.21.36[.]120, 172.67.193[.]253

7. Пивот кампании и виктимология

Пивот по извлечённому индикатору C2 (109.248.150[.]234) в публичных песочницах и репозиториях malware intelligence выявил не менее 33 связанных семплов, использующих ту же инфраструктуру управления. Темы приманок по всему кластеру последовательно связаны с морской логистикой и фрахтовыми операциями: подписанные договоры, коносаменты House и Master Bill of Lading (HBL/MBL), а также судоводные уведомления грузополучателю («pre-alert») перед прибытием груза.

Подделанная личность отправителя — российский морской перевозчик (FESCO) — напрямую согласуется с этим тематическим кластером, что указывает на целевую направленность кампании против логистических, экспедиторских и связанных с судоходством организаций, а не на общую, отраслево-независимую фишинговую рассылку. Волны доставки, связанные с этим кластером, наблюдаются как минимум с 2026-06-18, что указывает на устойчивую, многонедельную операцию, а не разовую оппортунистическую рассылку.

8. Индикаторы компрометации (IOC)

Тип	Значение	Описание
IP (C2)	109.248.150[.]234:443	Управляющий сервер XWorm (AS203557 SIA RixHost / DATA CLUB-NL, NL)
IP (стейджер)	185.27.134[.]124	Вспомогательный стейджер, доставляющий вариант загрузчика .vbs
IP (отправитель)	89.108.121[.]15	Реальный IP отправки письма со спуфом FESCO (SPF Fail, HELO rpnmail.fmf.ru)
Домен (спуф)	ABersenyov@fesco[.]com	Подделанный адрес отправителя под сотрудника FESCO
SHA256	37f7127bcae8388c61432dc2d46b0df36cb33690ebbc5b725b28b33dfb145d4b	Contract9021_06_07_26.exe (дроппер XWorm)
MD5	5053320a66a5c4989c44a932a8720b7d	Contract9021_06_07_26.exe
SHA256	e8e901194d86b29166d6028cc97d3b7559ecff413f20cd7b7f84601c2d9f2709	Contract9021_06_07_26.r11 (ZIP-архив, замаскированный под RAR)
SHA256	f9183d461a9ef71e1a0a97ddef54f5a785c3d4fa1ac6cb979a82206a52037928	Извлечённая полезная нагрузка / модуль с конфигом
SHA256	7776706d26fb2dfd7cb96910810bb4c3a02b343a228035a0ca4db3ccf8e4d26a	Связанный семпл — тот же кластер C2
SHA256	d4bc7db58a0b6207d2d24336833ae73a8cac77bf9f6bfe68ad1c33b52f990d0d	Связанный семпл — тот же кластер C2
SHA256	6bdd98cecb7ecf8240b8fd57497a952dd2850075339b3932f4e2c2285dda00c6	Связанный семпл — тот же кластер C2
SHA256	c8c385c10b1586728318f43b9dcafecfd46d8d6000984fe489bb1d219ea8b4f9	Связанный семпл — тот же кластер C2
SHA256	70c2fe27f67d5bd45f18c826a1dc1f852fa86b2de8271151a7b8c4d6d58f34d7	Связанный семпл — тот же кластер C2
SHA256	fe126b87922ff8049c4b19d6588324a3bb4874020b943e86de176445ebe7c7b9	Связанный семпл — тот же кластер C2
Mutex	70vLmgcqMEnUJOeL	Значение mutex XWorm
AES-ключ	bK5bLIZIB9durXZWd5PDkvR0hpNHk04+uqD7mNo2KtY=	Ключ шифрования трафика, извлечён из конфига

Путь файла	%AppData%\bin.exe	Путь установки для персистентности
Путь файла	USB.exe	Компонент распространения через съёмные носители

9. MITRE ATT&CK

Тактика / Техника	ID	Применение
Spearphishing Attachment	T1566.001	Доставка замаскированного ZIP-архива по почте
Malicious File	T1204.002	Запуск жертвой вложенного .exe, выданного за договор
Masquerade File Type	T1036.008	ZIP-архив переименован под фейковым расширением «.r11» для имитации тома RAR
Process Injection	T1055	Инъекция через SetThreadContext в незакреплённую память
Registry Run Keys / Startup Folder	T1547.001	Персистентность через ключ автозапуска и папку автозагрузки
Scheduled Task/Job	T1053.005	Запланированная задача для персистентности/исполнения
Impair Defenses: Disable or Modify Tools	T1562.001	Отключение Windows Defender через PowerShell и реестр
Command and Scripting Interpreter: PowerShell	T1059.001	PowerShell используется для обхода защиты
Replication Through Removable Media	T1091	Компонент USB.exe для распространения через съёмные носители
Steal Web Session Cookie	T1539	Кража cookie/данных сессии, хранимых браузером
Virtualization/Sandbox Evasion	T1497	Анти-анализные проверки по HW-ID и наличию IDE-диска
Encrypted Channel	T1573	AES-шифрованный трафик C2 поверх TLS на порту 443

10. Рекомендации

Немедленные действия

- Заблокировать хост C2 109.248.150[.]234 и вспомогательный стейджер 185.27.134[.]124 на уровне сетевого периметра/файрвола/DNS.

- Загрузить перечисленные хеши файлов в EDR/AV и в правила блокировки вложений почтового шлюза.
- Логистическим и судоходным организациям: с повышенной настороженностью относиться к незапрошенным письмам с темой «договор», «коносамент» или «pre-alert», содержащим архивные вложения.
- Настроить почтовые шлюзы на обнаружение и карантин архивных вложений, у которых заявленное расширение не соответствует истинной сигнатуре файла (например, файлы «.r11»/«.rNN», являющиеся по magic-байтам ZIP).

Долгосрочные меры

- Внедрить SPF, DKIM и DMARC с политикой reject (либо, как минимум, quarantine) — данное письмо провалило проверку SPF и было бы отфильтровано корректно настроенной почтовой системой.
- Мониторить конечные точки на характерное для XWorm поведение: изменения конфигурации Defender через PowerShell, неожиданные записи в ключе автозапуска, указывающие на %AppData%\bin.exe, а также исходящие TLS-соединения на нестандартные хосты по порту 443.
- Ограничить или мониторить использование съёмных носителей в средах, обрабатывающих чувствительную логистическую документацию, учитывая выявленную способность к USB-распространению.
- Учитывать, что XWorm — широко распространённый commodity RAT/билдер-набор; сам по себе факт использования этого семейства не указывает на сложного или связанного с государством субъекта, однако устойчивые тематические кампании против конкретного сектора требуют продолжения мониторинга.

11. Ссылки

- ThreatFox (abuse.ch) — отслеживание C2 ботнета XWorm для 109.248.150[.]234, с 2026-06-18.
- MITRE ATT&CK — техники, указанные в разделе 9 (attack.mitre.org).
- Публичные сервисы песочниц и репутации, использованные для пивота по C2 и кластеризации семплов.

TLP:CLEAR — Этот документ может распространяться без ограничений.